Dédale

Fiche de défense pour le jury

Orbis Pay est une entreprise fictive.

La menace défendue. Un contenu piégé vise deux lecteurs : le salarié et l'agent. Le salarié peut cliquer un lien de phishing, coller un secret ou envoyer un fichier hors de l'entreprise. L'agent IA interne lit un mail piégé, prend la consigne cachée pour une tâche et appelle un outil sensible avec ses propres droits. Dédale suit les deux chemins jusqu'au même dossier SOC, où un humain décide. Preuves hors Dédale : 33,1 % des salariés non formés échouent aux tests de phishing simulés, 4,1 % après un an (KnowBe4 2025) ; EchoLeak, CVE-2025-32711, fuite de données par Microsoft 365 Copilot sans action humaine (The Hacker News) ; injection de prompt via le serveur MCP de GitHub, mai 2025 (Invariant Labs).

Les contrôles

- Passerelle : tout appel d'outil de l'agent la traverse ; sur soupçon, il est retenu avant exécution et attend l'analyste.
- Droits minimaux : jeton limité aux droits de la tâche ; appel hors jeton bloqué, jeton révoqué.
- Canaris : faux secrets et faux mails ; un canari touché ouvre l'incident sans attendre le classement.
- Boîte noire : chaîne entrée, consigne, outil, sortie, riposte reconstruite ; texte piégé neutralisé avant stockage.
- Décision humaine : « couper » arrête la session et révoque le jeton, « reprendre » libère l'appel retenu.
- Exports : ECS, règles Sigma pour un SIEM, brouillon NIS2.
- Volet poste sans flicage : tout est traité en local, aucun contenu ne sort, seule une catégorie neutralisée remonte, le salarié garde la main (avertir, jamais bloquer). C'est ce que le DPO et le CSE voudront entendre.

Ce qu'on ne fait pas : tout bloquer, remplacer votre SIEM, classer vos documents.

Cible et modèle (hypothèses, aucun client)

Cible : entreprises régulées (finance avec DORA, applicable depuis janvier 2025 ; santé), 500 à 5 000 salariés, une équipe sécurité ou SOC, au moins un agent IA en production ou en pilote avancé, Microsoft 365 ou Google Workspace, un SIEM. À vérifier : fintech et paiement, assurtech et mutuelles, santé numérique ; grandes banques comme validateurs. Hors cible : moins de 250 salariés, sans équipe sécurité ni agents.

Personnes : le RSSI achète, l'analyste SOC utilise, le responsable IA ou data copilote, le DPO et la conformité valident, le CSE est consulté pour le volet poste.

Modèle : licence annuelle par agent supervisé, poste salarié en option, pilote de 3 mois, pas de prix affiché. Deux hypothèses à tester en dix entretiens avec des RSSI : un RSSI finance la supervision d'agents sur un budget sécurité existant ; la licence par agent reste lisible quand le nombre d'agents monte.

NIS2 est une directive européenne : la loi française de transposition est encore attendue, Dédale ne la présente pas comme déjà applicable en France.

Correspondances (repères, pas une certification)

OWASP Agentic ASI01 (détournement d'objectif), ASI02 (usage abusif des outils), ASI03 (abus d'identité) ; MITRE ATLAS AML.T0051.001, T0053, T0057 ; ATT&CK T1566 (scène salarié), T1552, T1048, T1567, T1200 typés sans mesure du banc ; NIST CSF 2.0 DE.CM-09, DE.AE-02, DE.AE-08, RS.MA-02, RS.AN-03, RS.MI-01 ; NIS2 art. 23 : Dédale prépare le brouillon d'alerte sous 24 h, l'humain qualifie et notifie.

Ce que le banc a mesuré le 10 octobre

Chaque campagne tourne contre un backend lancé pour elle, base SQLite temporaire ; un taux a pour dénominateur les sessions émises. Rapports dans `attaque/rapports/`.

Campagne `c1010184730f49a`, 100 sessions, 25 par type :

- humain et script : 0/50 classées agent IA, 0/50 incident ; 50/50 bonne classe ;
- agent IA externe : 25/25 classées, 25/25 incidents ;
- agent interne imité par le banc : 0/25 classées (« inconnu »). Le canari ouvre pourtant 25/25 incidents et suspend 25/25 sessions : au sens strict, la détection vaut 25/50 ;
- classement au 5^{e} événement, médiane 3,5 s en horloge simulée ; incident présent dans la réponse au POST, médiane 0,32 ms.

Campagne `c10101848586937`, 25 sessions jouées par la vraie bibliothèque `interne/` et sa passerelle : 25/25 classées, 25/25 incidents, 25/25 suspendues, 0/25 rapport envoyé. Classement en 6 ms médian (horloge réelle).

Non mesuré : délai de décision et de confinement (aucun analyste), agent externe contre le vrai `leurres/`, modèle réel.

Tests

173 tests réussis (backend 45, interne 35, leurres 19, poste 17, attaque 23, scripts de démo 34). Ils vérifient le prototype, pas une détection en production.

Limites

Métriques sur trafic synthétique produit par notre propre banc : elles montrent la cohérence du moteur, pas une détection réelle. L'outil MCP piégé est repéré par motifs, contournable par paraphrase ; le désarmeur en cours le renforce. Agents fictifs, scénarios scriptés, entreprise fictive. Journal horodaté, scellement en cours. Aucune intégration native (pas de capteur Mac, d'Outlook, de Gmail ni d'annuaire d'identités). Aucune validation réglementaire : le brouillon NIS2 n'est ni qualifié ni envoyé, les correspondances n'ont été auditées par personne.

Ce qu'on a fait, ce qu'on vend

Fait : prototype local (passerelle, droits minimaux, canaris, boîte noire, console SOC, exports). Feuille de route en trois étapes : (1) connecteurs réels Microsoft 365 et Google ; (2) étiquettes de sensibilité ; (3) authentification et journal persistant. On vend la supervision des agents IA, le volet poste en option.

Équipe : Guilhem (agents IA et technique), Paul (mails et business).

Rejouer une campagne : `cd attaque && uv run python campagne.py --mode autonome --n 25 --backend <url>`.
Parcours de démo : `docs/DEMO.md`.